1. SPRINT PLANNING DOCUMENTADO — SPRINT 1

Nota 2 — Sprint Review 1: Primer Incremento Funcional (20%)

Proyecto: Sistema de Gestión y Compra de Libros en Línea
Frontend (Vercel): https://sistema-de-gestion-three.vercel.app/
Backend Swagger (Render): https://libreria-backend-yhdj.onrender.com/docs
Repositorio GitHub: github.com/josedavidmarin/Sistema-de-Gesti-n-y-Compra-de-Libros-en-L-nea

Equipo de Desarrollo:
• Jose David Marín Giraldo (josedavid.marin@utp.edu.co)
• Edwin Osorio Cartagena
• Maicol Londoño Hernández
Base de Datos Cloud: PostgreSQL (Supabase) + SQLite local

1. Sprint Goal (Objetivo del Sprint)

Sprint Goal: *"Construir y desplegar en producción el núcleo operativo de seguridad, gestión de identidad y control de acceso basado en roles (RBAC) del sistema mediante autenticación JWT y cifrado bcrypt, garantizando el autoservicio de clientes, la administración auditada por el usuario Root y el bloqueo atómico de compras o reservas para cuentas administrativas (RF-031) en una arquitectura cliente-servidor funcional, probada y demostrable de extremo a extremo."*

2. Historias Comprometidas en el Sprint 1 (21 Story Points)

De acuerdo con la priorización MoSCoW de la Nota 1 y estimación Fibonacci (Planning Poker), el equipo comprometió 7 Historias de Usuario **Must Have** (7 SP por integrante):

ID	Título de la Historia de Usuario	Prioridad (MoSCoW)	Estimación	Responsable	Requisitos
HU-01	Registro de nuevos clientes con DNI único y contraseña cifrada	**Must Have**	**5 SP**	Edwin Osorio	RF-027, RF-029
HU-04	Inicio de sesión (Login) y emisión de Bearer Token JWT con roles tipados	**Must Have**	**3 SP**	Jose David Marín	RF-026, RF-028
HU-05	Cierre de sesión (Logout) e invalidación de credenciales en cliente y servidor	**Must Have**	**1 SP**	Jose David Marín	RF-026
HU-06	Cambio seguro de contraseña con validación obligatoria de clave previa	**Must Have**	**2 SP**	Edwin Osorio	RF-028
HU-07	Consulta y actualización de perfil, correspondencia y monedero virtual	**Must Have**	**3 SP**	Jose David Marín	RF-021, RF-028, RF-037
HU-02	Creación exclusiva de Administradores por Superadmin Root con auditoría	**Must Have**	**5 SP**	Maicol Londoño	RF-030
HU-03	Restricción estricta de compras y reservas para Administradores y Root	**Must Have**	**2 SP**	Maicol Londoño	RF-031

3. Justificación de Cada Historia Comprometida

3.1 Capacidad del Equipo (~3 Semanas)

El equipo de 3 integrantes dispuso de 3 semanas (~10 a 12 horas/semana por persona = **90 a 108 horas-hombre totales**). Considerando ~4.5 horas por Story Point (desarrollo fullstack, documentación en inglés, pruebas automatizadas, notebook y despliegue en la nube), comprometer **21 SP (7 SP por integrante)** garantizó una carga sostenible sin deuda técnica.

3.2 Dependencias Técnicas y Justificación Individual por Historia

- **HU-04 (Login JWT — 3 SP):** Cimiento técnico del sprint. Provee la firma HS256 y el inyector get_current_user del cual dependen directamente HU-02, HU-03, HU-05, HU-06 y HU-07.
- **HU-01 (Registro de Clientes — 5 SP):** Punto de entrada para compradores (rol CLIENTE). Implementa el modelo relacional, unicidad de DNI/email y cifrado bcrypt, habilitando cuentas reales para probar login y perfil.
- **HU-05 (Logout — 1 SP):** Cierra el ciclo de vida de la sesión iniciada en HU-04 limpiando credenciales en cliente (AuthContext) y confirmando en POST /auth/logout.
- **HU-07 (Perfil y Monedero — 3 SP):** Depende de HU-04 (GET/PUT /auth/me). Permite gestionar teléfono y dirección de envío (RF-021) y consultar el saldo del monedero virtual (RF-037), requisito previo para futuras compras.
- **HU-06 (Cambio de Contraseña — 2 SP):** Depende de HU-04 y HU-07. Cumple RF-028 verificando criptográficamente la contraseña actual e impidiendo reutilizar la misma clave antes de re-hashear con bcrypt.
- **HU-02 (Creación de Administradores por Root — 5 SP):** Depende de HU-04 y del guardián require_roles(['ROOT']). Cumple RF-030 (prohibido el autorregistro de administradores; solo Root los crea y audita). Es prerrequisito para que en el Sprint 2 los administradores gestionen libros.
- **HU-03 (Restricción de Compras RF-031 — 2 SP):** Depende de HU-01, HU-02 y HU-04. Implementa el middleware verify_client_only que bloquea con HTTP 403 Forbidden cualquier compra o reserva intentada por ADMINISTRADOR o ROOT.

3.3 Prioridad Frente al Resto del Backlog

Construir catálogo, inventario o carrito sin tener autenticados los 3 roles (ROOT, ADMINISTRADOR, CLIENTE) y sus permisos RBAC habría obligado a exponer endpoints sin seguridad o con usuarios ficticios. Por ello, el módulo de Identidad y Seguridad tuvo prioridad máxima.

4. Historias que Quedaron Fuera del Sprint 1 y Por Qué

- **Catálogo e Inventario por Ejemplar Físico (HU-08, HU-09, HU-10, HU-10b, HU-14 — 27 SP):** Requieren que el rol ADMINISTRADOR (HU-02) esté creado y auditado. Además, sumar 27 SP habría duplicado la capacidad del equipo. Pasan al **Sprint 2 (Nota 3)**.
- **Reservas 24h, Carrito y Pagos (HU-11, HU-12, HU-13 — 16 SP):** Dependen de que existan libros y ejemplares físicos en base de datos (Sprint 2). Pasan al **Sprint 3**.
- **Logística, Envíos y Devoluciones QR (HU-14, HU-15, HU-20, HU-21 — 14 SP):** Historias *Should Have / Could Have* que requieren compras previas. Pasan al **Sprint 4**.

5. Criterios de Aceptación por Historia Comprometida

- **HU-01 (Registro):** CA-01: DNI y email únicos + clave >= 6 caracteres en POST /auth/register retorna 201 Created con rol CLIENTE y hash bcrypt. CA-02: DNI o email repetido retorna 400 Bad Request. CA-03: Validación de confirmación de clave y Ley 1581.
- **HU-04 (Login JWT):** CA-01: Credenciales válidas en POST /auth/login retornan 200 OK y JWT (HS256, 24h, claims: sub, rol, user_id, nombre). CA-02: Clave o email erróneo retorna 401 Unauthorized. CA-03: Redirección automática según rol.
- **HU-05 (Logout):** CA-01: Al cerrar sesión, invoca POST /auth/logout (200 OK), limpia localStorage, pasa a VISITANTE y bloquea rutas privadas.
- **HU-06 (Cambio de Clave):** CA-01: Clave actual incorrecta en PUT /auth/change-password retorna 400 Bad Request. CA-02: Nueva clave igual a la actual retorna 400 Bad Request. CA-03: Clave válida re-hashea con bcrypt y retorna 200 OK.
- **HU-07 (Perfil y Monedero):** CA-01: GET /auth/me retorna perfil y saldo ($150.000 COP). CA-02: PUT /auth/me actualiza teléfono y dirección (200 OK). CA-03: Impide modificar DNI, email, rol o saldo.
- **HU-02 (Crear Admin por Root):** CA-01: Rol ROOT en POST /admin/create-admin crea ADMINISTRADOR auditado (201 Created). CA-02: CLIENTE o ADMINISTRADOR intentando acceder recibe 403 Forbidden. CA-03: Root puede activar/suspender cuentas.
- **HU-03 (Restricción RF-031):** CA-01/CA-02: ADMINISTRADOR o ROOT en POST /compras/validar-permiso-compra-reserva recibe 403 Forbidden. CA-03: CLIENTE recibe 200 OK.

6. Definition of Done (DoD) del Equipo

Una historia se considera 'DONE' (Terminada) únicamente cuando cumple estos 6 criterios:

1. **Integrada:** Backend (FastAPI + SQLAlchemy) + Base de Datos (PostgreSQL/SQLite) + Frontend (React/TS) comunicándose extremo a extremo.
2. **Documentada en inglés:** Docstrings PEP-257, esquemas Pydantic y comentarios JSDoc en inglés técnico.
3. **Probada automáticamente:** Casos de éxito y error (400, 401, 403) aprobados al 100% en backend/test_sprint1_api.py.
4. **Reproducible en Notebook:** Verificada con assert en notebooks/demo_sprint1.ipynb.
5. **Trazable en Git y Tablero:** Commits con prefijo HU-XX:, vinculada a su Issue en GitHub Projects y desplegada en Vercel + Render.
6. **Demostrable en vivo:** Operativa en tiempo real para la sustentación ante el Product Owner.